

Rapport des analyses de securite

Stagiaire: Mohamed Habib Baili

Encadrant: Baylassen

Entreprise: L2T

Projet: Krayin Laravel CRM

Date: 2026-06-28

Rapport des analyses de sécurité

Identification

- Stagiaire: Mohamed Habib Baili
- Encadrant: Baylassen
- Entreprise: L2T
- Projet: Krayin Laravel CRM
- Date: 2026-06-28

Objectif

Ce rapport présente les contrôles de sécurité réalisés et les vulnérabilités détectées dans le projet Laravel CRM.

Contrôles prévus dans la pipeline

Catégorie	Outil	Objectif
Dépendances PHP	Composer Audit	Identifier les CVE dans `composer.lock`
Dépendances JS	npm Audit	Identifier les CVE dans `package-lock.json`
Secrets	Gitleaks	Détecter tokens, clés API, mots de passe
SAST	Semgrep	Détecter patterns vulnérables dans le code PHP
Scan filesystem	Trivy	Identifier vulnérabilités et mauvaises configurations
DAST	OWASP ZAP	Tester l'application déployée dynamiquement

Résultat Composer Audit

Commande exécutée:

```
composer audit --format=json
```

Résumé observé:

Sévérité	Nombre
Critique	1
Haute	2
Moyenne	13
Basse	4
Non renseignée	1
Total	21

Principales dépendances concernées:

- phpoffice/phpspreadsheet: vulnérabilité critique.
- laravel/framework: vulnérabilités liées aux URL signées et validation email.
- symfony/mime, symfony/mailer, symfony/routing, symfony/http-foundation, symfony/http-kernel, symfony/yaml.
- guzzlehttp/guzzle et guzzlehttp/psr7.
- setasign/fpdf.

Résultat npm Audit

Commande exécutée:

```
npm audit --json
```

Résumé observé:

Sévérité	Nombre
Critique	1
Haute	2
Moyenne	13
Basse	4
Non renseignée	1
Total	21

Critique 0
Haute 1
Moyenne 1
Basse 0
Total 2

Dépendances concernées:

- vite: path traversal et contournement server . fs . deny.
- esbuild: exposition potentielle du serveur de développement.

Résultat SAST

Semgrep est configuré dans la pipeline avec le profil PHP:

```
config: p/php
```

Résultat local: non exécuté localement car l'outil est prévu dans GitHub Actions.

Résultat DAST

OWASP ZAP Baseline est configuré pour scanner:

```
http://127.0.0.1:8000
```

Résultat local: non exécuté localement. Le rapport sera produit par GitHub Actions sous forme zap-report.html et zap-report.json.

Risques couverts par les scénarios du cahier des charges

Scénario Couverture dans cette version
--- ---
SQL Injection Semgrep + ZAP baseline, à compléter par scénarios authentifiés
MITM Vérification headers/HTTPS en environnement cible
Broken Authentication Tests Feature existants + DAST à compléter
Session Hijacking Vérification cookies, SameSite, Secure, HttpOnly
Replay Attack À tester avec scénarios API spécifiques
Privilege Escalation À couvrir par tests de rôles et permissions
API Abuse À compléter par rate limiting et tests API
DoS Dépendances vulnérables + tests de limites à compléter
Credential Stuffing À compléter par rate limiting et lockout
Security Misconfiguration ZAP + configuration Laravel
Sensitive Data Exposure Gitleaks + ZAP + revue `.env`
Sender Spoofing À analyser si les modules email sont activés

Recommandations de correction

1. Mettre à jour les dépendances PHP vulnérables:

```
composer update guzzlehttp/guzzle guzzlehttp/psr7 laravel/framework phpoffice/phpspreadsheet
setasign/fpdf symfony/* --with-all-dependencies
```

2. Mettre à jour Vite après validation de compatibilité:

```
npm update vite
```

3. Ne pas exécuter Vite dev server exposé publiquement.
4. Configurer APP_DEBUG=false en test, préproduction et production.
5. Activer HTTPS et cookies Secure, HttpOnly, SameSite.
6. Ajouter des tests d'autorisation sur les rôles CRM.
7. Conserver les rapports CI comme preuves d'audit.